

NIMBUSGUARD TECHNOLOGIES, INC.

Data Protection and Privacy Policy

Data Classification, Encryption, Retention & Privacy Controls

Document ID:	NG-DPP-002	Version:	3.8
Effective Date:	February 1, 2026	Owner:	DPO – Marcus Chen
Classification:	Internal – Confidential	Status:	Approved

1. Data Classification

NimbusGuard classifies all data into four tiers. Classification must be applied at the point of creation or ingestion and reviewed whenever data is shared, migrated, or archived.

Level	Label	Description	Examples
4	Restricted	Highest sensitivity; regulatory/legal obligations	PHI, payment data, encryption keys, auth credentials
3	Confidential	Business-sensitive; internal use only	Source code, financial reports, customer contracts, audit logs
2	Internal	General internal information	Internal wikis, project plans, org charts, meeting notes
1	Public	Approved for external release	Marketing collateral, published APIs, press releases

2. Encryption Standards

2.1 Data at Rest

All data at rest is encrypted using AES-256-GCM. Encryption is enforced at the storage layer via AWS KMS (Key Management Service) with customer-managed keys (CMKs) available for enterprise customers. Database encryption uses Transparent Data Encryption (TDE) for PostgreSQL and Amazon Aurora instances. All S3 buckets enforce SSE-KMS with bucket policies preventing unencrypted uploads.

2.2 Data in Transit

All network communications are encrypted using TLS 1.3 (minimum TLS 1.2). Internal service-to-service communication uses mutual TLS (mTLS) via a service mesh (Istio). API endpoints enforce HSTS with a minimum max-age of 31536000 seconds. SSL/TLS certificates are managed through AWS Certificate Manager and rotated automatically.

2.3 Key Management

Encryption keys are managed through AWS KMS with the following controls: master keys are stored in FIPS 140-2 Level 3 validated HSMs; key rotation occurs automatically every 365 days for AWS-managed keys and can be configured by customers for CMKs; key access is logged to CloudTrail and monitored by the SOC; separation of duties ensures no single administrator can both create and use encryption keys.

3. Data Retention and Disposal

Data Category	Retention Period	Disposal Method
Customer application data	Duration of contract + 90 days	Cryptographic erasure + logical deletion
Authentication logs	13 months	Automated purge from SIEM
Audit trail / compliance logs	7 years	Archive to Glacier, then cryptographic erasure
Backup data	90 days (daily), 12 months (monthly)	Automated lifecycle deletion
Employee HR records	Duration of employment + 7 years	Secure shredding / cryptographic erasure
Marketing analytics	24 months	Anonymization then deletion

4. Privacy Controls

4.1 Regulatory Compliance

NimbusGuard complies with GDPR (EU), CCPA/CPRA (California), PIPEDA (Canada), and the Australian Privacy Act 1988. A dedicated Data Protection Officer (Marcus Chen) oversees privacy compliance and serves as the point of contact for supervisory authorities. NimbusGuard's EU representative (per GDPR Article 27) is NimbusGuard EU GmbH, located in Frankfurt, Germany.

4.2 Data Subject Rights

NimbusGuard supports all data subject rights under GDPR including: right of access (Article 15), right to rectification (Article 16), right to erasure (Article 17), right to restriction of processing (Article 18), right to data portability (Article 20), and right to object (Article 21). Data subject requests are processed within 30 calendar days. Requests can be submitted via privacy@nimbusguard.io or through the in-product privacy dashboard.

4.3 Data Processing Agreements

NimbusGuard maintains Data Processing Agreements (DPAs) with all customers who are data controllers under GDPR. Standard Contractual Clauses (SCCs) – EU Commission Decision 2021/914 – are incorporated for international data transfers. Transfer Impact Assessments (TIAs) are conducted for all new sub-processor engagements and reviewed annually.

4.4 Data Localization

Customer data is stored in the region selected during onboarding. Available regions: US-East (Virginia, us-east-1), US-West (Oregon, us-west-2), and EU-West (Frankfurt, eu-central-1). Data does not leave the selected region for processing purposes. Customers on the Enterprise plan may configure geo-fencing rules to further restrict data residency. Metadata required for global service routing is minimized and pseudonymized.

5. Tenant Data Isolation

NimbusGuard implements strict multi-tenant isolation at multiple layers:

- **Application layer:** Tenant context is enforced via JWT claims validated on every API request. Row-level security (RLS) policies in PostgreSQL ensure queries only return data for the authenticated tenant.
- **Network layer:** Each tenant's workloads run in dedicated Kubernetes namespaces with network policies restricting cross-namespace traffic.
- **Encryption layer:** Enterprise customers receive dedicated KMS keys ensuring cryptographic separation of data.
- **Audit layer:** All data access is logged with tenant ID, user ID, resource accessed, and action performed. Logs are immutable and stored in a write-once audit partition.